



Ch.Sandhya Rani

Theoretical Knowledge

1. Understanding Security Assessment

Objective: Learn how to evaluate systems without paid tools.

Explanation:

- Security Assessment: Identify weaknesses using frameworks (e.g., NIST guidelines).
- Types of Security Testing:
 - Vulnerability Assessment: Use tools like OpenVAS (open-source vulnerability scanner).
 - Penetration Testing: Simulate attacks with Kali Linux tools (Metasploit, Nmap).
 - Compliance Testing: Validate against standards using checklists (e.g., CIS Benchmarks).

2. VAPT Methodology

Objective: Follow a structured approach using methodologies.

Explanation:

- Phases:
 - a. Planning: Define scope with tools like Dradis CE.
 - b. Discovery: Use Nmap (network scanning) and OWASP ZAP (web app scanning).
 - c. Attack: Exploit vulnerabilities with Metasploit Framework.
 - d. Reporting: Use templates from "Pentest-Tools".
 - e. *How to Learn*: Practice the OWASP Web Security Testing Framework.

3. Security Standards & Compliance

Objective: Align with regulations using resources.

Explanation:

- Standards: GDPR, HIPAA, ISO 27001.
- *How to Learn*: Use the OWASP Top 10 to prioritize web vulnerabilities.

4. Risk Assessment Basics

Objective: Prioritize vulnerabilities with scoring systems.

Explanation:



- CVSS Calculator: Use the NVD CVSS Calculator .
- Risk Matrix: Categorize risks as High/Medium/Low using spreadsheets (Google Sheets/Excel).

5. Common Vulnerabilities

Objective: Identify flaws in labs/tools.

Explanation:

- Network Vulnerabilities: Misconfigurations, open ports (use Nmap).
- Web Vulnerabilities: SQLi, XSS (practice on OWASP Juice Shop).
 - *How to Learn*: Use labs to understand the practical approach:
 - Metasploitable (intentionally vulnerable VM).
 - VulnHub (vulnerable machines).

6. Documentation Fundamentals

Objective: Create reports with tools.

Explanation:

- Tools:
 - Dradis CE (collaborative reporting).
 - CherryTree (note-taking for technical findings).
-

Practical Application

1. Setup Testing Environment

Steps:

- Installed Kali Linux.
- Download **Metasploitable 3** (vulnerable VM) from GitHub.

Download the ova file from here:

<https://sourceforge.net/projects/metasploitable3-ub1404upgraded/files/>

Install Metasploitable3-ub1404.ova in VirtualBox

Download the ova file

in VirtualBox...click file >> import machine

browse for and select Metasploitable3-ub1404.ova

RAM is set at 2048MB, so maybe reconfigure ram as 4096 or whatever you want

deselect import hdd as vdi (if you want to keep the vmware format, if not; keep as is)

start the VM



login as username vagrant, password vagrant

- Metasploitable2

Vulnerable Web Applications to Practice and test Vulnerabilities in Web Applications

Metasploitable is an intentionally vulnerable Linux virtual machine. This VM can be used to conduct security training, test security tools, and practice common penetration testing techniques.

Download this from the below website.

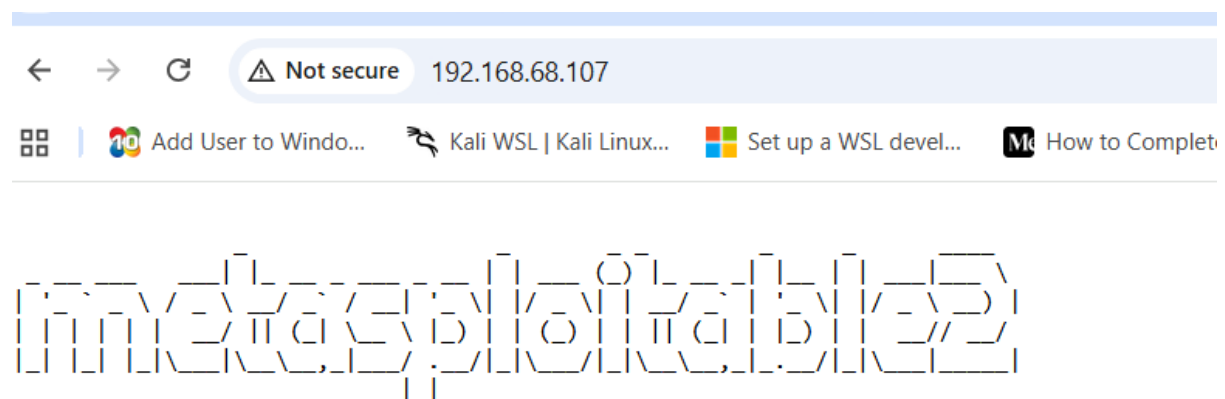
<https://sourceforge.net/projects/metasploitable/>

After downloading install it in Virtual Box.

After running the Metasploitable instance in Virtual box you have to login to the machine.

The default login and password is msfadmin:msfadmin. By using Ifconfig command you will find the IP address of the Metasploitable VM.

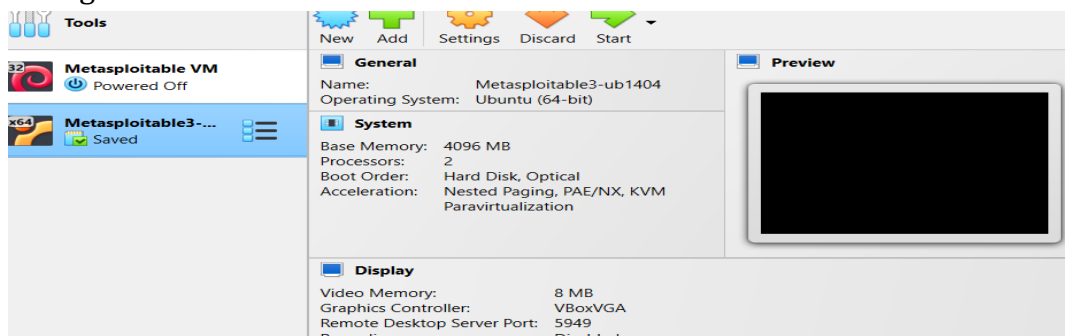
Once you enter the ip address in browser you will get the screen below.



- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)



- Configure VirtualBox to host VMs.



2. Vulnerability Scanning Tools:

- OpenVAS (integrated in Kali Linux).
- Nikto (web server scanner).
- Owasp ZAPProxy
 - Steps:

i. Scan Metasploitable with OpenVAS:

Kali: `sudo gym-start` ---Start the OpenVas

Scan the Metasploitable Machine -192.168.68.102

Log in to GVM (Greenbone Web UI)

- URL: <http://127.0.0.1:9392>
- Login: Use the **username** and **password** you set (e.g., admin / kali123)

2. Create a New Target

This defines what IP/domain to scan.

- ◆ Go to:

Configuration → Targets → click **"Create Target"**

Fill in the form:

- **Name:** Test Scan (or any name)
- **Hosts:** IP address or hostname (e.g., 192.168.68.102)
- **Port List:** Use default (All IANA assigned TCP ports)

Then click **"Save"**

3. Create a Task (Scan Job)

Go to:

Scans → Tasks → click **"Create Task"**

Fill in the form:

- **Name:** Scan My Target



- **Target:** Select the target you created earlier
- **Scan Config:** Use Full and fast (good default)
- Leave others as default and click **"Save"**

4. Start the Scan

In the **Tasks** list:

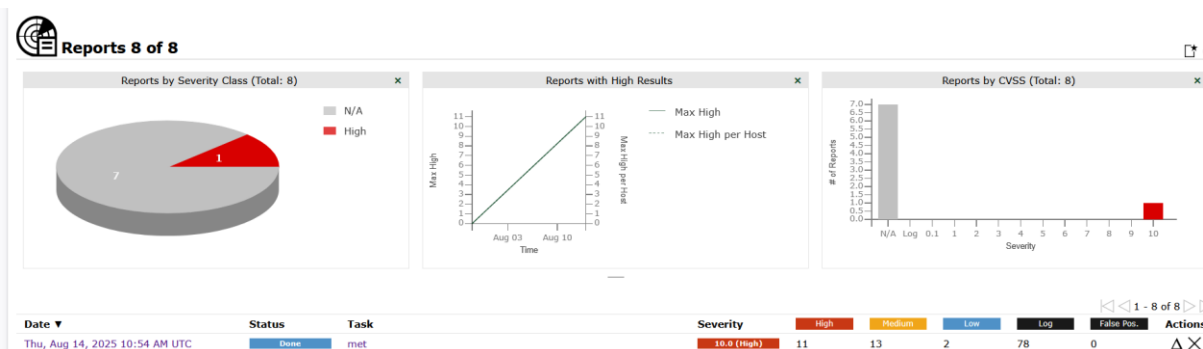
- Click the **play button** (🔍) next to your task

The scan will begin. You'll see its status change to:

- Requested → Running → Done

5. Wait for Scan to Complete

- Depending on target size and config, this can take from a few minutes to an hour
- You can refresh or monitor status live



6. View Results

Once the scan status is **"Done"**:

- Go to Scans → Reports
- Click your scan name to open the report
- You'll see:
 - Vulnerability summary
 - Severity (High, Medium, Low)
 - Affected ports/services
 - CVEs, exploits, and remediation tips

✓ Optional: Export Report

- Click **"Download"** icon
- Export as PDF, HTML, XML, etc.

- Analyze results (e.g., CVSS scores, CVE IDs).

Documenting Findings:

Report:



I Summary

=====

Scan started: Thu Aug 14 10:54:28 2025 UTC

Scan ended: Thu Aug 14 12:37:56 2025 UTC

Task: met

Host Summary

Host	High	Medium	Low	Log	FalsePositive
192.168.68.102	11	13	2	0	0

II Results per Host

=====

Host 192.168.68.102

Scanning of this host started at: Thu Aug 14 10:55:28 2025 UTC

Number of results: 26

Port Summary for Host 192.168.68.102

Service (Port)	Threat Level
21/tcp	High (CVSS: 10.0)
80/tcp	High (CVSS: 10.0)
general/tcp	High (CVSS: 10.0)
22/tcp	High (CVSS: 9.8)
6697/tcp	High (CVSS: 8.1)



631/tcp	High (CVSS: 7.5)
---------	------------------

Security Issues for Host 192.168.68.102

Issue

NVT: Drupal Coder RCE Vulnerability (SA-CONTRIB-2016-039) - Active Check

OID: 1.3.6.1.4.1.25623.1.0.105818

Threat: High (CVSS: 10.0)

Port: 80/tcp

Summary:

Drupal is prone to a remote code execution (RCE) vulnerability.

Vulnerability Detection Result:

Vulnerable URL: http://192.168.68.102/drupal/sites/all/modules/coder/coder_upgrade/scripts/coder_upgrade.run.php

Solution:

Solution type: VendorFix

Install the latest version.

Vulnerability Insight:

The Coder module checks your Drupal code against coding standards and other best practices. It can also fix coding standard violations!



and perform basic upgrades on modules. The module doesn't sufficiently validate user inputs in a script file that has the php extension. A malicious unauthenticated user can make requests directly to this file to execute arbitrary php code.

Vulnerability Detection Method:

Checks for known error message from affected modules.

Details:

Drupal Coder RCE Vulnerability (SA-CONTRIB-2016-039) - Active Check

(OID: 1.3.6.1.4.1.25623.1.0.105818)

Version used: 2023-07-21T05:05:22Z

References:

url: <https://www.drupal.org/node/2765575>

Issue

NVT: Operating System (OS) End of Life (EOL) Detection

OID: 1.3.6.1.4.1.25623.1.0.103674

Threat: High (CVSS: 10.0)

Port: general/tcp

Product detection result: cpe:/o:canonical:ubuntu_linux:14.04

Detected by: OS Detection Consolidation and Reporting (OID: 1.3.6.1.4.1.25623.1.0.105937)



Summary:

The Operating System (OS) on the remote host has reached the end of life (EOL) and should not be used anymore.

Vulnerability Detection Result:

The "Ubuntu" Operating System on the remote host has reached the end of life.

CPE: cpe:/o:canonical:ubuntu_linux:14.04

Installed version,

build or SP: 14.04

EOL date: 2024-04-01

EOL info: <https://wiki.ubuntu.com/Releases>

Impact:

An EOL version of an OS is not receiving any security updates from the vendor. Unfixed security vulnerabilities might be leveraged by an attacker to compromise the security of this host.

Solution:

Solution type: Mitigation

Update the OS on the remote host to a version which is still supported and receiving security updates by the vendor.

Note / Important: Please create an override for this result if the target host!

is a:

- Windows system with Extended Security Updates (ESU)
- System with additional 3rd-party / non-vendor security updates like e.g. from

m 'TuxCare',



'Freexian Extended LTS' or similar

Vulnerability Detection Method:

Checks if an EOL version of an OS is present on the target host.

Details:

Operating System (OS) End of Life (EOL) Detection

(OID: 1.3.6.1.4.1.25623.1.0.103674)

Version used: 2025-05-21T05:40:19Z

Product Detection Result:

Product:cpe:/o:canonical:ubuntu_linux:14.04

Method:OS Detection Consolidation and Reporting

(OID: 1.3.6.1.4.1.25623.1.0.105937)

Issue

NVT: ProFTPD `mod\_copy` Unauthenticated Copying Of Files Via SITE CPFR/CPTO

OID: 1.3.6.1.4.1.25623.1.0.105254

Threat: High (CVSS: 10.0)

Port: 21/tcp

Product detection result: cpe:/a:proftpd:proftpd:1.3.5

Detected by: ProFTPD Server Detection (FTP) (OID: 1.3.6.1.4.1.25623.1.0.900815)



Summary:

ProFTPD is prone to an unauthenticated copying of files vulnerability.

Vulnerability Detection Result:

The target was found to be vulnerable

Impact:

Under some circumstances this could result in remote code execution

Solution:

Solution type: VendorFix

Ask the vendor for an update

Vulnerability Detection Method:

Try to copy /etc/passwd to /tmp/passwd.copy with SITE CPFR/CPTO

Details:

ProFTPD `mod\_copy` Unauthenticated Copying Of Files Via SITE CPFR/CPTO

(OID: 1.3.6.1.4.1.25623.1.0.105254)

Version used: 2025-04-15T05:54:49Z

Product Detection Result:

Product:cpe:/a:proftpd:proftpd:1.3.5

Method:ProFTPD Server Detection (FTP)

(OID: 1.3.6.1.4.1.25623.1.0.900815)

References:



cve: CVE-2015-3306

url: http://bugs.proftpd.org/show_bug.cgi?id=4169

cert-bund: CB-K15/0791

cert-bund: CB-K15/0553

dfn-cert: DFN-CERT-2015-0839

dfn-cert: DFN-CERT-2015-0576

Issue

NVT: SSH Brute Force Logins With Default Credentials Reporting

OID: 1.3.6.1.4.1.25623.1.0.103239

Threat: High (CVSS: 9.8)

Port: 22/tcp

Summary:

It was possible to login into the remote SSH server using default credentials.

Vulnerability Detection Result:

It was possible to login with the following credentials <User>:<Password>
vagrant:vagrant

Impact:

This issue may be exploited by a remote attacker to e.g. gain access to sensitive information or modify system configuration.



Solution:

Solution type: Mitigation

Change the password as soon as possible.

Affected Software/OS:

The following products are known to use the default credentials

checked by the VT 'SSH Brute Force Logins With Default Credentials' (OID:

1.3.6.1.4.1.25623.1.0.108013) used for this reporting:

- CVE-2017-16523: MitraStar GPT-2541GNAC (HGU) 1.00(VNJ0)b1 and DSL-100HN-T1 E!

S_113WJY0b16 devices

- CVE-2020-29583: Zyxel Firewall / AP Controller

- CVE-2020-9473: S. Siedle & Soehne SG 150-0 Smart Gateway before 1.2.4

- CVE-2021-27797: Brocade Fabric OS

- CVE-2023-1944: minikube 1.29.0 and probably prior

- CVE-2024-22902: Vinchin Backup & Recovery

- CVE-2024-31970: AdTran SRG 834-5 HDC17600021F1 devices (with SmartOS 11.1.1.1!

1) during a window

of time when the device is being set up

- CVE-2024-46328: VONETS VAP11G-300 v3.3.23.6.9

- Various additional products like e.g. Ubiquiti EdgeMax / EdgeRouter, Crestro!

n AM-100 and similar

for which no CVE was assigned (See 'default_credentials.inc' file on the file !

system for a full

list)

Other products might be affected as well.



Vulnerability Insight:

As the VT 'SSH Brute Force Logins With Default Credentials'

(OID: 1.3.6.1.4.1.25623.1.0.108013) might run into a timeout the actual report!

ing of this

vulnerability takes place in this VT instead.

Vulnerability Detection Method:

Reports default credentials detected by the VT

'SSH Brute Force Logins With Default Credentials' (OID: 1.3.6.1.4.1.25623.1.0.108013).

Details:

SSH Brute Force Logins With Default Credentials Reporting

(OID: 1.3.6.1.4.1.25623.1.0.103239)

Version used: 2025-04-04T05:39:39Z

References:

cve: CVE-1999-0501

cve: CVE-1999-0502

cve: CVE-1999-0507

cve: CVE-1999-0508

cve: CVE-2005-1379

cve: CVE-2006-5288

cve: CVE-2009-3710

cve: CVE-2012-4577

cve: CVE-2016-1000245

cve: CVE-2017-16523

cve: CVE-2020-29583



cve: CVE-2020-9473

cve: CVE-2021-27797

cve: CVE-2023-1944

cve: CVE-2024-22902

cve: CVE-2024-31970

cve: CVE-2024-46328

url: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

cisa: Known Exploited Vulnerability (KEV) catalog

Issue

NVT: PHP < 5.6.30, 7.x < 7.0.15, 7.1.x < 7.1.1 Multiple Vulnerabilities (Jan 2017) - Linux

OID: 1.3.6.1.4.1.25623.1.0.108052

Threat: High (CVSS: 9.8)

Port: 80/tcp

Product detection result: cpe:/a:php:php:5.4.5

Detected by: PHP Detection (HTTP) (OID: 1.3.6.1.4.1.25623.1.0.800109)

Summary:

PHP is prone to multiple vulnerabilities.

Vulnerability Detection Result:

Installed version: 5.4.5

Fixed version: 5.6.30

Installation



path / port: 80/tcp

Solution:

Solution type: VendorFix

Update to version 5.6.30, 7.0.15, 7.1.1 or later.

Affected Software/OS:

PHP prior to version 5.6.30, 7.x prior to 7.0.15 and 7.1.x
prior to 7.1.1.

Vulnerability Insight:

The following flaws exist:

- CVE-2016-10161: Heap out of bounds read on unserialize in finish_nested_data!

()

- CVE-2016-10158: FPE when parsing a tag format

- CVE-2016-10168: Signed Integer Overflow gd_io.c

- CVE-2016-10167: DOS vulnerability in gdImageCreateFromGd2Ctx()

- CVE-2017-11147: Seg fault when loading hostile phar

- CVE-2016-10160: Memory corruption when loading hostile phar

- CVE-2016-10159: Crash while loading hostile phar archive

Vulnerability Detection Method:

Checks if a vulnerable version is present on the target host.

Details:

PHP < 5.6.30, 7.x < 7.0.15, 7.1.x < 7.1.1 Multiple Vulnerabilities (Jan 2017...

(OID: 1.3.6.1.4.1.25623.1.0.108052)

Version used: 2025-05-21T05:40:19Z



Product Detection Result:

Product:cpe:/a:php:php:5.4.5

Method:PHP Detection (HTTP)

(OID: 1.3.6.1.4.1.25623.1.0.800109)

References:

cve: CVE-2016-10158

cve: CVE-2016-10159

cve: CVE-2016-10160

cve: CVE-2016-10161

cve: CVE-2016-10167

cve: CVE-2016-10168

cve: CVE-2017-11147

url: <http://www.php.net/ChangeLog-5.php>

url: <http://www.php.net/ChangeLog-7.php>

url: <http://bugs.php.net/73825>

url: <http://bugs.php.net/73737>

url: <http://bugs.php.net/73869>

url: <http://bugs.php.net/73868>

url: <http://bugs.php.net/73773>

url: <http://bugs.php.net/73768>

url: <http://bugs.php.net/73764>

cert-bund: WID-SEC-2023-2718

cert-bund: CB-K17/1957

cert-bund: CB-K17/1575



cert-bund: CB-K17/1461

cert-bund: CB-K17/1358

cert-bund: CB-K17/1252

cert-bund: CB-K17/0527

cert-bund: CB-K17/0327

cert-bund: CB-K17/0318

cert-bund: CB-K17/0269

cert-bund: CB-K17/0264

cert-bund: CB-K17/0232

cert-bund: CB-K17/0182

cert-bund: CB-K17/0141

dfn-cert: DFN-CERT-2018-0835

dfn-cert: DFN-CERT-2017-2044

dfn-cert: DFN-CERT-2017-1647

dfn-cert: DFN-CERT-2017-1529

dfn-cert: DFN-CERT-2017-1420

dfn-cert: DFN-CERT-2017-1295

dfn-cert: DFN-CERT-2017-0532

dfn-cert: DFN-CERT-2017-0334

dfn-cert: DFN-CERT-2017-0325

dfn-cert: DFN-CERT-2017-0274

dfn-cert: DFN-CERT-2017-0270

dfn-cert: DFN-CERT-2017-0234

dfn-cert: DFN-CERT-2017-0179

dfn-cert: DFN-CERT-2017-0144



Issue

NVT: UnrealIRCd Authentication Spoofing Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.809883

Threat: High (CVSS: 8.1)

Port: 6697/tcp

Product detection result: cpe:/a:unrealircd:unrealircd:3.2.8.1

Detected by: UnrealIRCd Detection (OID: 1.3.6.1.4.1.25623.1.0.809884)

Summary:

UnrealIRCd is prone to authentication spoofing vulnerability.

Vulnerability Detection Result:

Installed version: 3.2.8.1

Fixed version: 3.2.10.7

Impact:

Successful exploitation of this vulnerability

will allows remote attackers to spoof certificate fingerprints and consequentl!

y

log in as another user.

Solution:

Solution type: VendorFix

Upgrade to UnrealIRCd 3.2.10.7,

or 4.0.6, or later.



Affected Software/OS:

UnrealIRCd before 3.2.10.7 and
4.x before 4.0.6.

Vulnerability Insight:

The flaw exists due to an error in
the 'm_authenticate' function in 'modules/m_sasl.c' script.

Vulnerability Detection Method:

Checks if a vulnerable version is present on the target host.

Details:

UnrealIRCd Authentication Spoofing Vulnerability

(OID: 1.3.6.1.4.1.25623.1.0.809883)

Version used: 2023-07-14T16:09:27Z

Product Detection Result:

Product:cpe:/a:unrealircd:unrealircd:3.2.8.1

Method:UnrealIRCd Detection

(OID: 1.3.6.1.4.1.25623.1.0.809884)

References:

cve: CVE-2016-7144

url: <http://seclists.org/oss-sec/2016/q3/420>

url: <http://www.securityfocus.com/bid/92763>

url: <http://www.openwall.com/lists/oss-security/2016/09/05/8>



url:

<https://github.com/unrealircd/unrealircd/commit/f473e355e1dc422c4f019dbf86bc50ba1a34a766>

url: https://bugs.unrealircd.org/main_page.php

Issue

NVT: Drupal Core SQLi Vulnerability (SA-CORE-2014-005) - Active Check

OID: 1.3.6.1.4.1.25623.1.0.105101

Threat: High (CVSS: 7.5)

Port: 80/tcp

Summary:

Drupal is prone to an SQL injection (SQLi) vulnerability.

Vulnerability Detection Result:

Vulnerable URL: <http://192.168.68.102/drupal/?q=node&destination=node>

Impact:

Exploiting this issue could allow an attacker to execute

arbitrary code, to gain elevated privileges and to compromise the application,!

access or modify

data, or exploit latent vulnerabilities in the underlying database.

Solution:

Solution type: VendorFix

Updates are available. Please see the references for more

information.



Affected Software/OS:

Drupal 7.x versions prior to 7.32 are vulnerable.

Vulnerability Insight:

Drupal fails to sufficiently sanitize user-supplied data before using it in an SQL query.

Vulnerability Detection Method:

Sends a special crafted HTTP POST request and checks the response.

Details:

Drupal Core SQLi Vulnerability (SA-CORE-2014-005) - Active Check

(OID: 1.3.6.1.4.1.25623.1.0.105101)

Version used: 2023-07-26T05:05:09Z

References:

cve: CVE-2014-3704

url: <https://www.drupal.org/forum/newsletters/security-advisories-for-drupal-core/2014-10-15/sa-core-2014-005-drupal-core-sql>

url: <http://www.securityfocus.com/bid/70595>

cert-bund: CB-K14/1301

cert-bund: CB-K14/0920

dfn-cert: DFN-CERT-2014-1369

dfn-cert: DFN-CERT-2014-0958

Issue



NVT: UnrealIRCd Backdoor

OID: 1.3.6.1.4.1.25623.1.0.80111

Threat: High (CVSS: 7.5)

Port: 6697/tcp

Product detection result: cpe:/a:unrealircd:unrealircd:3.2.8.1

Detected by: UnrealIRCd Detection (OID: 1.3.6.1.4.1.25623.1.0.809884)

Summary:

Detection of backdoor in UnrealIRCd.

Vulnerability Detection Result:

Vulnerability was detected according to the Vulnerability Detection Method.

Solution:

Solution type: VendorFix

Install latest version of unrealircd and check signatures of software you're installing.

Affected Software/OS:

The issue affects Unreal 3.2.8.1 for Linux. Reportedly package

Unreal3.2.8.1.tar.gz downloaded in November 2009 and later is affected. The MD5

sum of the

affected file is 752e46f2d873c1679fa99de3f52a274d. Files with MD5 sum of

7b741e94e867c0a7370553fd01506c66 are not affected.



Vulnerability Insight:

Remote attackers can exploit this issue to execute arbitrary system commands within the context of the affected application.

Vulnerability Detection Method:

Details:

UnrealIRCd Backdoor

(OID: 1.3.6.1.4.1.25623.1.0.80111)

Version used: 2025-03-21T05:38:29Z

Product Detection Result:

Product:cpe:/a:unrealircd:unrealircd:3.2.8.1

Method:UnrealIRCd Detection

(OID: 1.3.6.1.4.1.25623.1.0.809884)

References:

cve: CVE-2010-2075

url: <http://www.unrealircd.com/txt/unrealsecadvisory.20100612.txt>

url: <http://seclists.org/fulldisclosure/2010/Jun/277>

url: <http://www.securityfocus.com/bid/40820>

Issue

NVT: SSL/TLS: Report Vulnerable Cipher Suites for HTTPS

OID: 1.3.6.1.4.1.25623.1.0.108031



Threat: High (CVSS: 7.5)

Port: 631/tcp

Product detection result: cpe:/a:ietf:transport_layer_security

Detected by: SSL/TLS: Report Supported Cipher Suites (OID: 1.3.6.1.4.1.25623.1.0.802067)

Summary:

This routine reports all SSL/TLS cipher suites accepted by a service where attack vectors exists only on HTTPS services.

Vulnerability Detection Result:

'Vulnerable' cipher suites accepted by this service via the TLSv1.0 protocol:

TLS_RSA_WITH_3DES_EDE_CBC_SHA (SWEET32)

'Vulnerable' cipher suites accepted by this service via the TLSv1.1 protocol:

TLS_RSA_WITH_3DES_EDE_CBC_SHA (SWEET32)

'Vulnerable' cipher suites accepted by this service via the TLSv1.2 protocol:

TLS_RSA_WITH_3DES_EDE_CBC_SHA (SWEET32)

Impact:

This could allow remote attackers to obtain sensitive information or have other, unspecified impacts.

Solution:

Solution type: Mitigation

The configuration of this services should be changed so that it does not accept the listed cipher suites anymore.

Please see the references for more resources supporting you with this task.



Affected Software/OS:

All services accepting vulnerable SSL/TLS cipher suites via HTTPS.

Vulnerability Insight:

These rules are applied for the evaluation of the vulnerable cipher suites:

- 64-bit block cipher 3DES vulnerable to the SWEET32 attack (CVE-2016-2183).

Vulnerability Detection Method:

Checks previous collected cipher suites.

Details:

SSL/TLS: Report Vulnerable Cipher Suites for HTTPS

(OID: 1.3.6.1.4.1.25623.1.0.108031)

Version used: 2025-03-27T05:38:50Z

Product Detection Result:

Product:cpe:/a:ietf:transport_layer_security

Method:SSL/TLS: Report Supported Cipher Suites

(OID: 1.3.6.1.4.1.25623.1.0.802067)

References:

cve: CVE-2016-2183

cve: CVE-2016-6329

cve: CVE-2020-12872



url: <https://ssl-config.mozilla.org>

url:

<https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TG02102/BSI-TR-02102-1.html>

url: https://www.bsi.bund.de/EN/Themen/Oeffentliche-Verwaltung/Mindeststandards/TLS-Protokoll/TLS-Protokoll_node.html

url:

<https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03116/BSI-TR-03116-4.html>

url:

https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Mindeststandards/Mindeststandard_BSI_TLS_Version_2_4.html

url: <https://web.archive.org/web/20240113175943/https://www.bettercrypto.org>

url: <https://www.enisa.europa.eu/publications/algorithms-key-size-and-parameters-report-2014>

url: <https://sweet32.info>

cert-bund: WID-SEC-2024-1277

cert-bund: WID-SEC-2024-0209

cert-bund: WID-SEC-2024-0064

cert-bund: WID-SEC-2022-2226

cert-bund: WID-SEC-2022-1955

cert-bund: CB-K21/1094

cert-bund: CB-K20/1023

cert-bund: CB-K20/0321

cert-bund: CB-K20/0314

cert-bund: CB-K20/0157

cert-bund: CB-K19/0618

cert-bund: CB-K19/0615

cert-bund: CB-K18/0296

cert-bund: CB-K17/1980



cert-bund: CB-K17/1871

cert-bund: CB-K17/1803

cert-bund: CB-K17/1753

cert-bund: CB-K17/1750

cert-bund: CB-K17/1709

cert-bund: CB-K17/1558

cert-bund: CB-K17/1273

cert-bund: CB-K17/1202

cert-bund: CB-K17/1196

cert-bund: CB-K17/1055

cert-bund: CB-K17/1026

cert-bund: CB-K17/0939

cert-bund: CB-K17/0917

cert-bund: CB-K17/0915

cert-bund: CB-K17/0877

cert-bund: CB-K17/0796

cert-bund: CB-K17/0724

cert-bund: CB-K17/0661

cert-bund: CB-K17/0657

cert-bund: CB-K17/0582

cert-bund: CB-K17/0581

cert-bund: CB-K17/0506

cert-bund: CB-K17/0504

cert-bund: CB-K17/0467

cert-bund: CB-K17/0345

cert-bund: CB-K17/0098

cert-bund: CB-K17/0089



cert-bund: CB-K17/0086

cert-bund: CB-K17/0082

cert-bund: CB-K16/1837

cert-bund: CB-K16/1830

cert-bund: CB-K16/1635

cert-bund: CB-K16/1630

cert-bund: CB-K16/1624

cert-bund: CB-K16/1622

cert-bund: CB-K16/1500

cert-bund: CB-K16/1465

cert-bund: CB-K16/1307

cert-bund: CB-K16/1296

dfn-cert: DFN-CERT-2025-0041

dfn-cert: DFN-CERT-2021-1618

dfn-cert: DFN-CERT-2021-0775

dfn-cert: DFN-CERT-2021-0770

dfn-cert: DFN-CERT-2021-0274

dfn-cert: DFN-CERT-2020-2141

dfn-cert: DFN-CERT-2020-0368

dfn-cert: DFN-CERT-2019-1455

dfn-cert: DFN-CERT-2019-0068

dfn-cert: DFN-CERT-2018-1296

dfn-cert: DFN-CERT-2018-0323

dfn-cert: DFN-CERT-2017-2070

dfn-cert: DFN-CERT-2017-1954

dfn-cert: DFN-CERT-2017-1885

dfn-cert: DFN-CERT-2017-1831



dfn-cert: DFN-CERT-2017-1821
dfn-cert: DFN-CERT-2017-1785
dfn-cert: DFN-CERT-2017-1626
dfn-cert: DFN-CERT-2017-1326
dfn-cert: DFN-CERT-2017-1239
dfn-cert: DFN-CERT-2017-1238
dfn-cert: DFN-CERT-2017-1090
dfn-cert: DFN-CERT-2017-1060
dfn-cert: DFN-CERT-2017-0968
dfn-cert: DFN-CERT-2017-0947
dfn-cert: DFN-CERT-2017-0946
dfn-cert: DFN-CERT-2017-0904
dfn-cert: DFN-CERT-2017-0816
dfn-cert: DFN-CERT-2017-0746
dfn-cert: DFN-CERT-2017-0677
dfn-cert: DFN-CERT-2017-0675
dfn-cert: DFN-CERT-2017-0611
dfn-cert: DFN-CERT-2017-0609
dfn-cert: DFN-CERT-2017-0522
dfn-cert: DFN-CERT-2017-0519
dfn-cert: DFN-CERT-2017-0482
dfn-cert: DFN-CERT-2017-0351
dfn-cert: DFN-CERT-2017-0090
dfn-cert: DFN-CERT-2017-0089
dfn-cert: DFN-CERT-2017-0088
dfn-cert: DFN-CERT-2017-0086
dfn-cert: DFN-CERT-2016-1943



dfn-cert: DFN-CERT-2016-1937

dfn-cert: DFN-CERT-2016-1732

dfn-cert: DFN-CERT-2016-1726

dfn-cert: DFN-CERT-2016-1715

dfn-cert: DFN-CERT-2016-1714

dfn-cert: DFN-CERT-2016-1588

dfn-cert: DFN-CERT-2016-1555

dfn-cert: DFN-CERT-2016-1391

dfn-cert: DFN-CERT-2016-1378

Issue

NVT: FTP Brute Force Logins With Default Credentials Reporting

OID: 1.3.6.1.4.1.25623.1.0.108718

Threat: High (CVSS: 7.5)

Port: 21/tcp

Summary:

It was possible to login into the remote FTP server using
weak/known credentials.

Vulnerability Detection Result:

It was possible to login with the following credentials <User>:<Password>
vagrant:vagrant

Impact:

This issue may be exploited by a remote attacker to e.g. gain
access to sensitive information or modify system configuration.



Solution:

Solution type: Mitigation

Change the password as soon as possible.

Vulnerability Insight:

The following devices are / software is known to be affected:

- CVE-2001-1594: Codonics printer FTP service as used in GE Healthcare eNTEGRA!

P&R

- CVE-2013-7404: GE Healthcare Discovery NM 750b
- CVE-2014-9198: Schneider Electric ETG3000 FactoryCast HMI gateways
- CVE-2015-7261: QNAP iArtist Lite distributed with QNAP Signage Station
- CVE-2016-8731: Foscam C1 devices
- CVE-2017-8218: vsftpd on TP-Link C2 and C20i devices
- CVE-2018-9068: IMM2 for IBM and Lenovo System x
- CVE-2018-17771: Ingenico Telium 2 PoS terminals
- CVE-2018-19063, CVE-2018-19064: Foscam C2 and Opticam i5 devices

Note: As the VT 'FTP Brute Force Logins With Default Credentials' (OID:

1.3.6.1.4.1.25623.1.0.108717) might run into a timeout the actual reporting of!

this vulnerability

takes place in this VT instead.

Vulnerability Detection Method:

Reports weak/known credentials detected by the VT

'FTP Brute Force Logins With Default Credentials' (OID: 1.3.6.1.4.1.25623.1.0.108717).

Details:



FTP Brute Force Logins With Default Credentials Reporting

(OID: 1.3.6.1.4.1.25623.1.0.108718)

Version used: 2025-05-13T05:41:39Z

References:

cve: CVE-1999-0501

cve: CVE-1999-0502

cve: CVE-1999-0507

cve: CVE-1999-0508

cve: CVE-2001-1594

cve: CVE-2013-7404

cve: CVE-2014-9198

cve: CVE-2015-7261

cve: CVE-2016-8731

cve: CVE-2017-8218

cve: CVE-2018-9068

cve: CVE-2018-17771

cve: CVE-2018-19063

cve: CVE-2018-19064

Issue

NVT: Test HTTP dangerous methods

OID: 1.3.6.1.4.1.25623.1.0.10498

Threat: High (CVSS: 7.5)

Port: 80/tcp



Summary:

Misconfigured web servers allows remote clients to perform dangerous HTTP methods such as PUT and DELETE.

Vulnerability Detection Result:

We could upload the following files via the PUT method at this web server:

<http://192.168.68.102/uploads/puttest1045126336.html>

We could delete the following files via the DELETE method at this web server:

<http://192.168.68.102/uploads/puttest1045126336.html>

Impact:

- Enabled PUT method: This might allow an attacker to upload and run arbitrary code on this web server.
- Enabled DELETE method: This might allow an attacker to delete additional files on this web server.

Solution:

Solution type: Mitigation

Use access restrictions to these dangerous HTTP methods or disable them completely.

Affected Software/OS:

Web servers with enabled PUT and/or DELETE methods.

Vulnerability Detection Method:



Checks if dangerous HTTP methods such as PUT and DELETE are enabled and can be misused to upload or delete files.

Details:

Test HTTP dangerous methods

(OID: 1.3.6.1.4.1.25623.1.0.10498)

Version used: 2023-08-01T13:29:10Z

References:

url: <http://www.securityfocus.com/bid/12141>

owasp: OWASP-CM-001

Issue

NVT: jQuery < 1.9.0 XSS Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.141636

Threat: Medium (CVSS: 6.1)

Port: 80/tcp

Summary:

jQuery is prone to a cross-site scripting (XSS) vulnerability.

Vulnerability Detection Result:

Installed version: 1.6.2

Fixed version: 1.9.0

Installation



path / port: /phpmyadmin/setup/../../js/jquery/jquery-1.6.2.js

Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):

- Identified file: <http://192.168.68.102/phpmyadmin/setup/../../js/jquery/jquery-1.6.2.js>
- Referenced at: <http://192.168.68.102/phpmyadmin/setup/>

Solution:

Solution type: VendorFix

Update to version 1.9.0 or later.

Affected Software/OS:

jQuery prior to version 1.9.0.

Vulnerability Insight:

The jQuery(strInput) function does not differentiate selectors

from HTML in a reliable fashion. In vulnerable versions, jQuery determined whether the input was

HTML by looking for the '<' character anywhere in the string, giving attackers more flexibility

when attempting to construct a malicious payload. In fixed versions, jQuery only deems the input

to be HTML if it explicitly starts with the '<' character, limiting exploitability only to

attackers who can control the beginning of a string, which is far less common.

Vulnerability Detection Method:

Checks if a vulnerable version is present on the target host.



Details:

jQuery < 1.9.0 XSS Vulnerability

(OID: 1.3.6.1.4.1.25623.1.0.141636)

Version used: 2023-07-14T05:06:08Z

References:

cve: CVE-2012-6708

url: <https://bugs.jquery.com/ticket/11290>

cert-bund: WID-SEC-2022-0673

cert-bund: CB-K22/0045

cert-bund: CB-K18/1131

dfn-cert: DFN-CERT-2025-1803

dfn-cert: DFN-CERT-2023-1197

dfn-cert: DFN-CERT-2020-0590

Issue

NVT: jQuery < 1.9.0 XSS Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.141636

Threat: Medium (CVSS: 6.1)

Port: 80/tcp

Summary:

jQuery is prone to a cross-site scripting (XSS) vulnerability.



Vulnerability Detection Result:

Installed version: 1.6.2

Fixed version: 1.9.0

Installation

path / port: /phpmyadmin/js/jquery/jquery-1.6.2.js

Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):

- Identified file: <http://192.168.68.102/phpmyadmin/js/jquery/jquery-1.6.2.js>
- Referenced at: <http://192.168.68.102/phpmyadmin/>

Solution:

Solution type: VendorFix

Update to version 1.9.0 or later.

Affected Software/OS:

jQuery prior to version 1.9.0.

Vulnerability Insight:

The jQuery(strInput) function does not differentiate selectors

from HTML in a reliable fashion. In vulnerable versions, jQuery determined whether the input was

HTML by looking for the '<' character anywhere in the string, giving attackers! more flexibility

when attempting to construct a malicious payload. In fixed versions, jQuery only deems the input

to be HTML if it explicitly starts with the '<' character, limiting exploitability only to

attackers who can control the beginning of a string, which is far less common.



Vulnerability Detection Method:

Checks if a vulnerable version is present on the target host.

Details:

jQuery < 1.9.0 XSS Vulnerability

(OID: 1.3.6.1.4.1.25623.1.0.141636)

Version used: 2023-07-14T05:06:08Z

References:

cve: CVE-2012-6708

url: <https://bugs.jquery.com/ticket/11290>

cert-bund: WID-SEC-2022-0673

cert-bund: CB-K22/0045

cert-bund: CB-K18/1131

dfn-cert: DFN-CERT-2025-1803

dfn-cert: DFN-CERT-2023-1197

dfn-cert: DFN-CERT-2020-0590

Issue

NVT: Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)

OID: 1.3.6.1.4.1.25623.1.0.150713

Threat: Medium (CVSS: 5.3)

Port: 22/tcp

Product detection result: cpe:/a:ietf:secure_shell_protocol



Detected by: SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565)

Summary:

The remote SSH server is configured to allow / support weak key exchange (KEX) algorithm(s).

Vulnerability Detection Result:

The remote SSH server supports the following weak KEX algorithm(s):

KEX algorithm	Reason
---------------	--------

-----!	

diffie-hellman-group-exchange-sha1	Using SHA-1
------------------------------------	-------------

diffie-hellman-group1-sha1	Using Oakley Group 2 (a 1024-bit MODP group!)
) and SHA-1	

Impact:

An attacker can quickly break individual connections.

Solution:

Solution type: Mitigation

Disable the reported weak KEX algorithm(s)

- 1024-bit MODP group / prime KEX algorithms:

Alternatively use elliptic-curve Diffie-Hellmann in general, e.g. Curve 25519.

Vulnerability Insight:

- 1024-bit MODP group / prime KEX algorithms:

Millions of HTTPS, SSH, and VPN servers all use the same prime numbers for Dif!



Diffie-Hellman key

exchange. Practitioners believed this was safe as long as new key exchange messages

were generated

for every connection. However, the first step in the number field sieve-the most

efficient

algorithm for breaking a Diffie-Hellman connection-is dependent only on this prime

time.

A nation-state can break a 1024-bit prime.

Vulnerability Detection Method:

Checks the supported KEX algorithms of the remote SSH server.

Currently weak KEX algorithms are defined as the following:

- non-elliptic-curve Diffie-Hellmann (DH) KEX algorithms with 1024-bit MODP group / prime
- ephemeral key exchange groups uses SHA-1
- using RSA 1024-bit modulus key

Details:

Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)

(OID: 1.3.6.1.4.1.25623.1.0.150713)

Version used: 2024-06-14T05:05:48Z

Product Detection Result:

Product:cpe:/a:ietf:secure_shell_protocol

Method:SSH Protocol Algorithms Supported

(OID: 1.3.6.1.4.1.25623.1.0.105565)



References:

url: <https://weakdh.org/sysadmin.html>

url: <https://www.rfc-editor.org/rfc/rfc9142>

url: <https://www.rfc-editor.org/rfc/rfc9142#name-summary-guidance-for-implem>

url: <https://www.rfc-editor.org/rfc/rfc6194>

url: <https://www.rfc-editor.org/rfc/rfc4253#section-6.5>

Issue

NVT: Weak Host Key Algorithm(s) (SSH)

OID: 1.3.6.1.4.1.25623.1.0.117687

Threat: Medium (CVSS: 5.3)

Port: 22/tcp

Product detection result: cpe:/a:ietf:secure_shell_protocol

Detected by: SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565)

Summary:

The remote SSH server is configured to allow / support weak host
key algorithm(s).

Vulnerability Detection Result:

The remote SSH server supports the following weak host key algorithm(s):

host key algorithm | Description

-----!



ssh-dss | Digital Signature Algorithm (DSA) / Digital Signature Standard (DSS)

Solution:

Solution type: Mitigation

Disable the reported weak host key algorithm(s).

Vulnerability Detection Method:

Checks the supported host key algorithms of the remote SSH server.

Currently weak host key algorithms are defined as the following:

- ssh-dss: Digital Signature Algorithm (DSA) / Digital Signature Standard (DSS)

)

Details:

Weak Host Key Algorithm(s) (SSH)

(OID: 1.3.6.1.4.1.25623.1.0.117687)

Version used: 2024-06-14T05:05:48Z

Product Detection Result:

Product:cpe:/a:ietf:secure_shell_protocol

Method:SSH Protocol Algorithms Supported

(OID: 1.3.6.1.4.1.25623.1.0.105565)

References:

url: <https://www.rfc-editor.org/rfc/rfc8332>

url: <https://www.rfc-editor.org/rfc/rfc8709>



url: <https://www.rfc-editor.org/rfc/rfc4253#section-6.6>

Issue

NVT: Drupal 7.0 Information Disclosure Vulnerability - Active Check

OID: 1.3.6.1.4.1.25623.1.0.902574

Threat: Medium (CVSS: 5.0)

Port: 80/tcp

Summary:

Drupal is prone to an information disclosure vulnerability.

Vulnerability Detection Result:

Vulnerable URL:

[http://192.168.68.102/drupal/modules/simpletest/tests/upgrade/dr!](http://192.168.68.102/drupal/modules/simpletest/tests/upgrade/drupal-6.upload.database.php)

upal-6.upload.database.php

Impact:

Successful exploitation will allow attacker to obtain sensitive information that could aid in further attacks.

Solution:

Solution type: WillNotFix

No known solution was made available for at least one year

since the disclosure of this vulnerability. Likely none will be provided anymo!

re. General solution

options are to upgrade to a newer release, disable respective features, remove!



the product or

replace the product by another one.

Affected Software/OS:

Drupal version 7.0 is known to be affected.

Vulnerability Insight:

The flaw is due to insufficient error checking, allows remote

attackers to obtain sensitive information via a direct request to a .php file,!

which reveals the

installation path in an error message.

Vulnerability Detection Method:

Details:

Drupal 7.0 Information Disclosure Vulnerability - Active Check

(OID: 1.3.6.1.4.1.25623.1.0.902574)

Version used: 2021-12-01T11:10:56Z

References:

cve: CVE-2011-3730

url: http://code.google.com/p/inspathx/source/browse/trunk/paths_vuln/!_README

url: http://code.google.com/p/inspathx/source/browse/trunk/paths_vuln/drupal-7.0

Issue

NVT: Sensitive File Disclosure (HTTP)



OID: 1.3.6.1.4.1.25623.1.0.107305

Threat: Medium (CVSS: 5.0)

Port: 80/tcp

Summary:

The script attempts to identify files containing sensitive data at the remote web server.

Vulnerability Detection Result:

The following files containing sensitive information were identified:

Description: Microsoft IIS / ASP.NET Core Module web.config file accessible. This could contain sensitive information about the structure of the application /! web server and shouldn't be accessible.

Match: <configuration>

<system.webServer>

Used regex: ^\s*<(configuration|system\.web(Server)?>

Extra match 1: </system.webServer>

</configuration>

Used regex: ^\s*</(configuration|system\.web(Server)?>

URL: http://192.168.68.102/drupal/web.config

Impact:

Based on the information provided in these files an attacker

might be able to gather additional info and/or sensitive data like usernames and passwords.

Solution:



Solution type: Mitigation

The sensitive files shouldn't be accessible via a web server.

Restrict access to it or remove it completely.

Vulnerability Insight:

Currently the script is checking for files like e.g.:

- Software (Blog, CMS) configuration or log files
- Web / application server configuration / password files (.htaccess, .htpasswd,

web.config,

web.xml, ...)

- Cloud (e.g. AWS) configuration files
- Files containing API keys for services / providers
- Database backup files
- Editor / history files
- SSH or SSL/TLS Private Keys
- CVE-2017-16894: Laravel framework environment/.env files

Vulnerability Detection Method:

Enumerate the remote web server and check if sensitive files are accessible.

Details:

Sensitive File Disclosure (HTTP)

(OID: 1.3.6.1.4.1.25623.1.0.107305)

Version used: 2025-05-09T15:42:11Z

References:

cve: CVE-2017-16894



Issue

NVT: Unprotected Web App / Device Installers (HTTP)

OID: 1.3.6.1.4.1.25623.1.0.107307

Threat: Medium (CVSS: 5.0)

Port: 80/tcp

Summary:

The script attempts to identify installation/setup pages of various web apps/devices that are publicly accessible and not protected by e.g! . account restrictions or having their setup finished.

Vulnerability Detection Result:

The following web app/device installers are unprotected/have not finished their ! setup and are publicly accessible (URL:Description):

http://192.168.68.102/phpmyadmin/setup/index.php - CubeCart / phpMyAdmin install!

er

Impact:

It is possible to install or reconfigure the software. In doing so, the attacker could overwrite existing configurations. It could be possible! for the attacker to gain access to the base system



Solution:

Solution type: Mitigation

Setup and/or installation pages for Web Apps should not be publicly accessible via a web server. Restrict access to it, remove it completely or finish the setup of the application / device.

Vulnerability Detection Method:

Enumerate the remote web server and check if unprotected web apps/devices are accessible for installation.

Details:

Unprotected Web App / Device Installers (HTTP)

(OID: 1.3.6.1.4.1.25623.1.0.107307)

Version used: 2025-07-22T05:43:35Z

Issue

NVT: Cleartext Transmission of Sensitive Information via HTTP

OID: 1.3.6.1.4.1.25623.1.0.108440

Threat: Medium (CVSS: 4.8)

Port: 80/tcp

Summary:

The host / application transmits sensitive information (username, passwords) in cleartext via HTTP.



Vulnerability Detection Result:

The following input fields were identified (URL:input name):

`http://192.168.68.102/drupal/:pass`

`http://192.168.68.102/drupal/?D=A:pass`

`http://192.168.68.102/payroll_app.php:password`

`http://192.168.68.102/phpmyadmin/:pma_password`

`http://192.168.68.102/phpmyadmin/?D=A:pma_password`

`http://192.168.68.102/phpmyadmin/changelog.php:pma_password`

`http://192.168.68.102/phpmyadmin/index.php:pma_password`

`http://192.168.68.102/phpmyadmin/license.php:pma_password`

`http://192.168.68.102/phpmyadmin/url.php:pma_password`

Impact:

An attacker could use this situation to compromise or eavesdrop on the

HTTP communication between the client and the server using a man-in-the-middle!

attack to get access to

sensitive data like usernames or passwords.

Solution:

Solution type: Workaround

Enforce the transmission of sensitive data via an encrypted SSL/TLS connection.

Additionally make sure the host / application is redirecting all users to the !

secured SSL/TLS connection before

allowing to input sensitive data into the mentioned functions.

Affected Software/OS:

Hosts / applications which doesn't enforce the transmission of sensitive data via



a an

encrypted SSL/TLS connection.

Vulnerability Detection Method:

Evaluate previous collected information and check if the host / application is n!

ot

enforcing the transmission of sensitive data via an encrypted SSL/TLS connecti!

on.

The script is currently checking the following:

- HTTP Basic Authentication (Basic Auth)
- HTTP Forms (e.g. Login) with input field of type 'password'

Details:

Cleartext Transmission of Sensitive Information via HTTP

(OID: 1.3.6.1.4.1.25623.1.0.108440)

Version used: 2023-09-07T05:05:21Z

References:

url: https://www.owasp.org/index.php/Top_10_2013-A2-Broken_Authentication_and_Session_Management

url: https://www.owasp.org/index.php/Top_10_2013-A6-Sensitive_Data_Exposure

url: <https://cwe.mitre.org/data/definitions/319.html>

Issue

NVT: FTP Unencrypted Cleartext Login

OID: 1.3.6.1.4.1.25623.1.0.108528

Threat: Medium (CVSS: 4.8)



Port: 21/tcp

Summary:

The remote host is running a FTP service that allows cleartext logins over unencrypted connections.

Vulnerability Detection Result:

The remote FTP service accepts logins without a previous sent 'AUTH TLS' command!

. Response(s):

Non-anonymous sessions: 331 Password required for openvasvt

Anonymous sessions: 331 Anonymous login ok, send your complete email address!
as your password

Impact:

An attacker can uncover login names and passwords by sniffing traffic to the FTP service.

Solution:

Solution type: Mitigation

Enable FTPS or enforce the connection via the 'AUTH TLS' command. Please see the manual of the FTP service for more information.

Vulnerability Detection Method:

Tries to login to a non FTPS enabled FTP service without sending a 'AUTH TLS' command first and checks if the service is accepting the login without enforcing the use of the 'AUTH TLS' command.



Details:

FTP Unencrypted Cleartext Login

(OID: 1.3.6.1.4.1.25623.1.0.108528)

Version used: 2023-12-20T05:05:58Z

Issue

NVT: jQuery < 1.6.3 XSS Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.141637

Threat: Medium (CVSS: 4.3)

Port: 80/tcp

Summary:

jQuery is prone to a cross-site scripting (XSS) vulnerability.

Vulnerability Detection Result:

Installed version: 1.6.2

Fixed version: 1.6.3

Installation

path / port: /phpmyadmin/js/jquery/jquery-1.6.2.js

Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):

- Identified file: <http://192.168.68.102/phpmyadmin/js/jquery/jquery-1.6.2.js>

- Referenced at: <http://192.168.68.102/phpmyadmin/>

Solution:



Solution type: VendorFix

Update to version 1.6.3 or later.

Affected Software/OS:

jQuery prior to version 1.6.3.

Vulnerability Insight:

Cross-site scripting (XSS) vulnerability in jQuery before 1.6.3,

when using location.hash to select elements, allows remote attackers to inject!

arbitrary web

script or HTML via a crafted tag.

Vulnerability Detection Method:

Checks if a vulnerable version is present on the target host.

Details:

jQuery < 1.6.3 XSS Vulnerability

(OID: 1.3.6.1.4.1.25623.1.0.141637)

Version used: 2023-07-14T05:06:08Z

References:

cve: CVE-2011-4969

url: <https://blog.jquery.com/2011/09/01/jquery-1-6-3-released/>

cert-bund: CB-K17/0195

dfn-cert: DFN-CERT-2017-0199

dfn-cert: DFN-CERT-2016-0890



Issue

NVT: SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection

OID: 1.3.6.1.4.1.25623.1.0.117274

Threat: Medium (CVSS: 4.3)

Port: 631/tcp

Product detection result: cpe:/a:ietf:transport_layer_security:1.0

Detected by: SSL/TLS: Version Detection (OID: 1.3.6.1.4.1.25623.1.0.105782)

Summary:

It was possible to detect the usage of the deprecated TLSv1.0 and/or TLSv1.1 protocol on this system.

Vulnerability Detection Result:

In addition to TLSv1.2+ the service is also providing the deprecated TLSv1.0 and! TLSv1.1 protocols and supports one or more ciphers. Those supported ciphers can! be found in the 'SSL/TLS: Report Supported Cipher Suites' (OID: 1.3.6.1.4.1.256! 23.1.0.802067) VT.

Impact:

An attacker might be able to use the known cryptographic flaws to eavesdrop the connection between clients and the service to get access to sensitive data transferred within the secured connection.

Furthermore newly uncovered vulnerabilities in this protocols won't receive security updates



anymore.

Solution:

Solution type: Mitigation

It is recommended to disable the deprecated TLSv1.0 and/or

TLSv1.1 protocols in favor of the TLSv1.2+ protocols.

Please see the references for more resources supporting you with this task.

Affected Software/OS:

- All services providing an encrypted communication using the TLSv1.0 and/or TLSv1.1 protocols
- CVE-2023-41928: Kiloview P1 4G and P2 4G Video Encoder
- CVE-2024-41270: Gorush v1.18.4
- CVE-2025-3200: Multiple products from Wiesemann & Theis

Vulnerability Insight:

The TLSv1.0 and TLSv1.1 protocols contain known cryptographic flaws like:

- CVE-2011-3389: Browser Exploit Against SSL/TLS (BEAST)
- CVE-2015-0204: Factoring Attack on RSA-EXPORT Keys Padding Oracle On Downgrade

Legacy

Encryption (FREAK)

Vulnerability Detection Method:

Checks the used TLS protocols of the services provided by this system.

Details:



SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection

(OID: 1.3.6.1.4.1.25623.1.0.117274)

Version used: 2025-04-30T05:39:51Z

Product Detection Result:

Product:cpe:/a:ietf:transport_layer_security:1.0

Method:SSL/TLS: Version Detection

(OID: 1.3.6.1.4.1.25623.1.0.105782)

References:

cve: CVE-2011-3389

cve: CVE-2015-0204

cve: CVE-2023-41928

cve: CVE-2024-41270

cve: CVE-2025-3200

url: <https://ssl-config.mozilla.org>

url:

<https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/Publications/TechGuidelines/TG02102/BSI-TR-02102-1.html>

url: https://www.bsi.bund.de/EN/Themen/Oeffentliche-Verwaltung/Mindeststandards/TLS-Protokoll/TLS-Protokoll_node.html

url:

<https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03116/BSI-TR-03116-4.html>

url:

https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Mindeststandards/Mindeststandard_BSI_TLS_Version_2_4.html

url: <https://web.archive.org/web/20240113175943/https://www.bettercrypto.org>



url: <https://www.enisa.europa.eu/publications/algorithms-key-size-and-parameters-report-2014>

url: <https://datatracker.ietf.org/doc/rfc8996/>

url: <https://vnhacker.blogspot.com/2011/09/beast.html>

url: <https://web.archive.org/web/20201108095603/https://censys.io/blog/freak>

url: <https://certvde.com/en/advisories/VDE-2025-031/>

url: <https://gist.github.com/nyxfqq/cfae38fada582a0f576d154be1aeb1fc>

url: <https://advisories.ncsc.nl/advisory?id=NCSC-2024-0273>

Issue

NVT: jQuery < 1.6.3 XSS Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.141637

Threat: Medium (CVSS: 4.3)

Port: 80/tcp

Summary:

jQuery is prone to a cross-site scripting (XSS) vulnerability.

Vulnerability Detection Result:

Installed version: 1.6.2

Fixed version: 1.6.3

Installation

path / port: /phpmyadmin/setup/./js/jquery/jquery-1.6.2.js

Detection info (see OID: 1.3.6.1.4.1.25623.1.0.150658 for more info):

- Identified file: <http://192.168.68.102/phpmyadmin/setup/./js/jquery/jquery-1.6.2.js>

- Referenced at: <http://192.168.68.102/phpmyadmin/setup/>



Solution:

Solution type: VendorFix

Update to version 1.6.3 or later.

Affected Software/OS:

jQuery prior to version 1.6.3.

Vulnerability Insight:

Cross-site scripting (XSS) vulnerability in jQuery before 1.6.3,

when using `location.hash` to select elements, allows remote attackers to inject!

arbitrary web

script or HTML via a crafted tag.

Vulnerability Detection Method:

Checks if a vulnerable version is present on the target host.

Details:

jQuery < 1.6.3 XSS Vulnerability

(OID: 1.3.6.1.4.1.25623.1.0.141637)

Version used: 2023-07-14T05:06:08Z

References:

cve: CVE-2011-4969

url: <https://blog.jquery.com/2011/09/01/jquery-1-6-3-released/>

cert-bund: CB-K17/0195

dfn-cert: DFN-CERT-2017-0199

dfn-cert: DFN-CERT-2016-0890



Issue

NVT: Weak Encryption Algorithm(s) Supported (SSH)

OID: 1.3.6.1.4.1.25623.1.0.105611

Threat: Medium (CVSS: 4.3)

Port: 22/tcp

Product detection result: cpe:/a:ietf:secure_shell_protocol

Detected by: SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565)

Summary:

The remote SSH server is configured to allow / support weak encryption algorithm(s).

Vulnerability Detection Result:

The remote SSH server supports the following weak client-to-server encryption algorithm(s):

3des-cbc

aes128-cbc

aes192-cbc

aes256-cbc

arcfour

arcfour128

arcfour256

blowfish-cbc



cast128-cbc

rijndael-cbc@lysator.liu.se

The remote SSH server supports the following weak server-to-client encryption al!

gorithm(s):

3des-cbc

aes128-cbc

aes192-cbc

aes256-cbc

arcfour

arcfour128

arcfour256

blowfish-cbc

cast128-cbc

rijndael-cbc@lysator.liu.se

Solution:

Solution type: Mitigation

Disable the reported weak encryption algorithm(s).

Vulnerability Insight:

- The 'arcfour' cipher is the Arcfour stream cipher with 128-bit

keys. The Arcfour cipher is believed to be compatible with the RC4 cipher [SCH!

NEIER]. Arcfour

(and RC4) has problems with weak keys, and should not be used anymore.

- The 'none' algorithm specifies that no encryption is to be done. Note that t!

his method provides



no confidentiality protection, and it is NOT RECOMMENDED to use it.

- A vulnerability exists in SSH messages that employ CBC mode that may allow an attacker to recover plaintext from a block of ciphertext.

Vulnerability Detection Method:

Checks the supported encryption algorithms (client-to-server and server-to-client) of the remote SSH server.

Currently weak encryption algorithms are defined as the following:

- Arcfour (RC4) cipher based algorithms
- 'none' algorithm
- CBC mode cipher based algorithms

Details:

Weak Encryption Algorithm(s) Supported (SSH)

(OID: 1.3.6.1.4.1.25623.1.0.105611)

Version used: 2024-06-14T05:05:48Z

Product Detection Result:

Product:cpe:/a:ietf:secure_shell_protocol

Method:SSH Protocol Algorithms Supported

(OID: 1.3.6.1.4.1.25623.1.0.105565)

References:

url: <https://www.rfc-editor.org/rfc/rfc8758>

url: <https://www.kb.cert.org/vuls/id/958563>

url: <https://www.rfc-editor.org/rfc/rfc4253#section-6.3>



Issue

NVT: TCP Timestamps Information Disclosure

OID: 1.3.6.1.4.1.25623.1.0.80091

Threat: Low (CVSS: 2.6)

Port: general/tcp

Summary:

The remote host implements TCP timestamps and therefore allows to compute the uptime.

Vulnerability Detection Result:

It was detected that the host implements RFC1323/RFC7323.

The following timestamps were retrieved with a delay of 1 seconds in-between:

Packet 1: 347922

Packet 2: 348213

Impact:

A side effect of this feature is that the uptime of the remote host can sometimes be computed.

Solution:

Solution type: Mitigation

To disable TCP timestamps on linux add the line

'net.ipv4.tcp_timestamps = 0' to /etc/sysctl.conf. Execute 'sysctl -p' to appl!



y the settings at

runtime.

To disable TCP timestamps on Windows execute 'netsh int tcp set global timesta!
mps=disabled'

Starting with Windows Server 2008 and Vista, the timestamp can not be complete!
ly disabled.

The default behavior of the TCP/IP stack on this Systems is to not use the Tim!
estamp options when

initiating TCP connections, but use them if the TCP peer that is initiating co!
mmunication includes

them in their synchronize (SYN) segment.

See the references for more information.

Affected Software/OS:

TCP implementations that implement RFC1323/RFC7323.

Vulnerability Insight:

The remote host implements TCP timestamps, as defined by
RFC1323/RFC7323.

Vulnerability Detection Method:

Special IP packets are forged and sent with a little delay in

between to the target IP. The responses are searched for a timestamps. If foun!
d, the timestamps
are reported.

Details:

TCP Timestamps Information Disclosure



(OID: 1.3.6.1.4.1.25623.1.0.80091)

Version used: 2023-12-15T16:10:08Z

References:

url: <https://datatracker.ietf.org/doc/html/rfc1323>

url: <https://datatracker.ietf.org/doc/html/rfc7323>

url: <https://web.archive.org/web/20151213072445/http://www.microsoft.com/en-us/download/details.aspx?id=9152>

url: <https://www.fortiguard.com/psirt/FG-IR-16-090>

Issue

NVT: Weak MAC Algorithm(s) Supported (SSH)

OID: 1.3.6.1.4.1.25623.1.0.105610

Threat: Low (CVSS: 2.6)

Port: 22/tcp

Product detection result: cpe:/a:ietf:secure_shell_protocol

Detected by: SSH Protocol Algorithms Supported (OID: 1.3.6.1.4.1.25623.1.0.105565)

Summary:

The remote SSH server is configured to allow / support weak MAC algorithm(s).

Vulnerability Detection Result:

The remote SSH server supports the following weak client-to-server MAC algorithm!
(s):



hmac-md5

hmac-md5-96

hmac-md5-96-etm@openssh.com

hmac-md5-etm@openssh.com

hmac-sha1-96

hmac-sha1-96-etm@openssh.com

umac-64-etm@openssh.com

umac-64@openssh.com

The remote SSH server supports the following weak server-to-client MAC algorithm!

(s):

hmac-md5

hmac-md5-96

hmac-md5-96-etm@openssh.com

hmac-md5-etm@openssh.com

hmac-sha1-96

hmac-sha1-96-etm@openssh.com

umac-64-etm@openssh.com

umac-64@openssh.com

Solution:

Solution type: Mitigation

Disable the reported weak MAC algorithm(s).

Vulnerability Detection Method:

Checks the supported MAC algorithms (client-to-server and server-to-client) of the remote SSH server.

Currently weak MAC algorithms are defined as the following:



- MD5 based algorithms
- 96-bit based algorithms
- 64-bit based algorithms
- 'none' algorithm

Details:

Weak MAC Algorithm(s) Supported (SSH)

(OID: 1.3.6.1.4.1.25623.1.0.105610)

Version used: 2024-06-14T05:05:48Z

Product Detection Result:

Product:cpe:/a:ietf:secure_shell_protocol

Method:SSH Protocol Algorithms Supported

(OID: 1.3.6.1.4.1.25623.1.0.105565)

References:

url: <https://www.rfc-editor.org/rfc/rfc6668>

url: <https://www.rfc-editor.org/rfc/rfc4253#section-6.4>

2. Nikto (web server scanner):

Nikto is a great tool that can be used to detect server misconfigurations. To use it, type in the following command:

URL to Attack: <http://zero.webappsecurity.com/>

When we run the Nikto from Kali linux we found admin folder.



Not secure zero.webappsecurity.com/admin/users.html

Zero Bank

Users

Name	Password	SSN
Leeroy Jenkins	VIZ10AWT8VL	536-48-3789
Stephen Bowen	OTZ07BXM0BE	607-58-7435
Linus Moran	FKO04SXA7TI	247-54-1719
Nero Chan	TXJ77CQO5EI	578-13-3713
Kadeem Higgins	MFC50OQE7VO	449-20-3206
Quinn Burks	HWZ97ZUM3NK	008-70-6738
Davis Thompson	RGD78SHB0TG	574-56-1932
Lester Keller	EIJ79NLT0TP	330-58-4012

```
(root@DiffDell)~# nikto -host http://zero.webappsecurity.com/
- Nikto v2.5.0
-----
+ Target IP: 54.82.22.214
+ Target Hostname: zero.webappsecurity.com
+ Target Port: 80
+ Start Time: 2025-08-18 09:21:24 (GMT5.5)
-----
+ Server: Apache-Coyote/1.1
+ /: Retrieved access-control-allow-origin header: *.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerability-content-type-header/
+ : Server banner changed from 'Apache-Coyote/1.1' to 'Apache/2.2.6 (Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_perl/2.0.4 PHP/5.2.6'
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS, PATCH .
+ HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ HTTP method: 'PATCH' may allow client to issue patch commands to server. See RFC-5789.
+ ERROR: Error limit (20) reached for host, giving up. Last error: error reading HTTP response
+ Scan terminated: 15 error(s) and 8 item(s) reported on remote host
+ End Time: 2025-08-18 09:34:55 (GMT5.5) (811 seconds)
-----
```

Nikto Vulnerability Scan Report

Target Information

Target: http://zero.webappsecurity.com/

Target IP: 54.82.22.214

Scan Date: 18 Aug 2025

Tool Used: Nikto v2.5.0



Scan Findings

Category	Description	Risk	Recommendation
Server Information	Server banner exposed: Apache-Coyote/1.1 → Apache/2.2.6 (Win32)	Information Disclosure	Hide or obfuscate server version details (ServerTokens, ServerSignature in Apache).
Missing Security Headers	X-Frame-Options header not present (Clickjacking risk).	High	Add header: X-Frame-Options: SAMEORIGIN
Missing Security Headers	X-Content-Type-Options not set (MIME-sniffing risk).	Medium	Add header: X-Content-Type-Options: nosniff
Dangerous HTTP Methods	Allowed methods: PUT, DELETE, TRACE, PATCH.	High	Disable dangerous methods in Apache config (LimitExcept directive).
Errors	Nikto scan terminated with 20 errors (likely due to WAF or dropped connections).	Low	Review server logs and confirm no rate limiting/WAF interference.

Conclusion

The scan identified missing security headers, exposure of dangerous HTTP methods, and server version disclosure. These vulnerabilities can lead to exploits such as Clickjacking, MIME-based attacks, and unauthorized file upload/deletion. It is recommended to harden the server configuration by applying the security headers, restricting HTTP methods, and hiding version details.

3. OWASP ZAP Proxy

- The OWASP ZAP (Zed Attack Proxy) is a free and open-source web application security scanner. It is intended for use by both newcomers to application security and professional penetration testers. It has been designated as a Flagship project by the Open Web Application Security Project (OWASP).

- 70



CYART

inquiry@cyart.io

www.cyart.io